

# DOKUMEN KOMPILASI TEKNIS

---

## Sistem Informasi Lost & Found IPB

### Implementasi Protokol Keamanan Informasi

---

**Mata Kuliah :** Keamanan Informasi (KOM1315) **Semester :** Genap 2025/2026 **Program Studi :** Ilmu Komputer, IPB University **Jenis Dokumen :** Dokumen Kompilasi Akhir (Final Technical Report) **Kelompok 2 :**

- Syafiq Syadidul Azmi (G6401231075)
  - Muhammad Faqih (G6401231081)
  - Luqman Fadillah Santoso (G6401231136)
- 

## DAFTAR ISI

1. [Latar Belakang dan Rumusan Masalah](#)
  2. [Deskripsi Sistem](#)
  3. [Identifikasi Aset](#)
  4. [Threat Modeling dan Vulnerability Assessment](#)
  5. [Arsitektur Keamanan](#)
  6. [Implementasi Modul Kriptografi](#)
  7. [Stack Teknologi](#)
  8. [Endpoint API Lengkap](#)
  9. [Skema Database](#)
  10. [Protokol AAA](#)
  11. [Pengujian Keamanan](#)
  12. [Rencana Implementasi dan Kemajuan](#)
  13. [Referensi](#)
-

# 1. Latar Belakang dan Rumusan Masalah

## 1.1 Latar Belakang

Kampus IPB University sebagai institusi dengan puluhan ribu civitas akademika aktif setiap harinya menghadapi permasalahan umum: kehilangan barang. Berdasarkan observasi tim, penanganan barang hilang dan temuan saat ini masih dilakukan secara informal — melalui grup media sosial, pesan WhatsApp, atau laporan lisan kepada petugas keamanan. Pendekatan ad-hoc ini menghadirkan sejumlah risiko keamanan informasi yang serius:

- **Tidak ada verifikasi identitas** bagi pelapor maupun pengklaim barang.
- **Data pribadi pengguna** (nomor telepon, foto KTP) tersebar tanpa perlindungan kriptografis.
- **Tidak ada mekanisme audit trail** — tidak ada catatan siapa yang mengakses informasi, kapan, dan dari mana.
- **Tidak ada kendali akses** — semua pihak memiliki akses terhadap semua informasi.
- **Proses klaim tidak terverifikasi** — rentan terhadap klaim palsu.

## 1.2 Rumusan Masalah

1. Bagaimana merancang sistem lost & found berbasis web yang menerapkan autentikasi kuat dan manajemen sesi berbasis kriptografi?
2. Bagaimana mengimplementasikan mekanisme otorisasi berbasis peran (RBAC) untuk membedakan hak akses antar jenis pengguna?
3. Bagaimana memastikan integritas dan kerahasiaan data pengguna melalui teknik hashing password dan enkripsi data sensitif?
4. Bagaimana membangun sistem audit trail yang mencatat seluruh aktivitas pengguna untuk keperluan akuntabilitas?

## 1.3 Tujuan

1. Membangun sistem web RESTful **Lost & Found IPB** yang fungsional menggunakan FastAPI dan PostgreSQL.
2. Mengimplementasikan **Password Hashing** menggunakan algoritma Argon2 dan BCrypt.
3. Mengimplementasikan **JSON Web Token (JWT)** berbasis HMAC-SHA256 untuk autentikasi stateless.

4. Mengimplementasikan **Role-Based Access Control (RBAC)** dengan tiga tingkat peran: UMUM, CIVITAS, dan ADMIN.
5. Mengimplementasikan **enkripsi Fernet (AES-128-CBC)** untuk data identitas sensitif pengguna.
6. Membangun **Audit Logging** otomatis untuk mencatat seluruh aktivitas API.

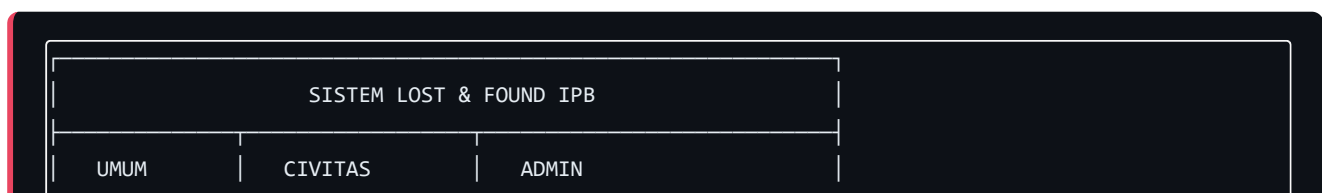
## 2. Deskripsi Sistem

**Nama Sistem:** Lost & Found IPB (FoundIt) **Jenis Aplikasi:** RESTful Web API (FastAPI) + Web Client **Base URL:** <http://localhost:8000> **API Documentation:** <http://localhost:8000/docs>

### 2.1 Fitur Utama

|                                   |                                                                     |
|-----------------------------------|---------------------------------------------------------------------|
|                                   |                                                                     |
| <b>Registrasi &amp; Login</b>     | Registrasi dengan enkripsi data identitas + login OAuth2 dengan JWT |
| <b>Pelaporan Barang Hilang</b>    | Civitas terautentikasi dapat melaporkan barang hilang beserta foto  |
| <b>Pelaporan Barang Temuan</b>    | Civitas dapat melaporkan barang yang ditemukan di kampus            |
| <b>Pencarian &amp; Filter</b>     | Pencarian barang berdasarkan jenis laporan, lokasi, dan tanggal     |
| <b>Klaim Kepemilikan</b>          | Mekanisme klaim terstruktur dengan bukti teks dan foto              |
| <b>Review Klaim</b>               | Admin memverifikasi klaim dan menentukan status persetujuan         |
| <b>Notifikasi</b>                 | Notifikasi otomatis saat klaim diajukan atau diputuskan             |
| <b>Audit Log</b>                  | Pencatatan seluruh aktivitas API untuk akuntabilitas (AAA)          |
| <b>Enkripsi Dokumen Identitas</b> | KTP/identitas user disimpan dalam bentuk terenkripsi (Fernet)       |

### 2.2 Peran Pengguna



|              |                         |                           |
|--------------|-------------------------|---------------------------|
|              | AKADEMIKA               |                           |
| • Lihat item | • Semua hak UMUM        | • Semua hak CIVITAS       |
| • Registrasi | • Laporkan item         | • Review & approve klaim  |
|              | • Ajukan klaim          | • Manajemen pengguna      |
|              | • Lihat riwayat sendiri | • Akses audit log         |
|              |                         | • Lihat dokumen identitas |

Deteksi peran Civitas dilakukan otomatis berdasarkan domain email `@ipb.ac.id` atau `@apps.ipb.ac.id`.

### 3. Identifikasi Aset

#### 3.1 Aset Informasi (Data)

| A-01 | Kredensial Pengguna (email, password hash)  | <b>RAHASIA</b> | Sangat Tinggi | Database <code>users</code>                                   |
|------|---------------------------------------------|----------------|---------------|---------------------------------------------------------------|
| A-02 | Data Profil Pengguna (nama, telepon, peran) | INTERNAL       | Tinggi        | Database <code>users</code>                                   |
| A-03 | Dokumen Identitas (KTP terenkripsi)         | <b>RAHASIA</b> | Sangat Tinggi | Filesystem <code>/storage/identity/</code> (Fernet encrypted) |
| A-04 | Nomor Identitas (NIK terenkripsi)           | <b>RAHASIA</b> | Sangat Tinggi | Database <code>users</code> (Fernet encrypted)                |
| A-05 | Foto Bukti Klaim                            | INTERNAL       | Tinggi        | Filesystem <code>/storage/claims/</code>                      |
| A-06 | Data Barang Hilang/Temuan                   | PUBLIK         | Sedang        | Database <code>items</code>                                   |
| A-07 | Riwayat Klaim & Status Review               | INTERNAL       | Tinggi        | Database <code>claim</code>                                   |
| A-08 | JWT Access Token                            | <b>RAHASIA</b> | Sangat Tinggi | Client-side (Header)                                          |
| A-09 | JWT Refresh Token                           | <b>RAHASIA</b> | Sangat Tinggi | Client-side                                                   |

|      |                                      |          |               |                                  |
|------|--------------------------------------|----------|---------------|----------------------------------|
| A-10 | Secret Key Aplikasi & Encryption Key | RAHASIA  | Sangat Tinggi | Environment Variable             |
| A-11 | Audit Log                            | INTERNAL | Tinggi        | Database <code>audit_logs</code> |

### 3.2 Aset Perangkat Lunak

|      |                                      |                                                         |
|------|--------------------------------------|---------------------------------------------------------|
|      |                                      |                                                         |
| A-12 | Backend FastAPI                      | Logika bisnis dan endpoint API                          |
| A-13 | Database PostgreSQL                  | Penyimpanan data persisten                              |
| A-14 | Modul <code>digital_signature</code> | Implementasi autentikasi, JWT, hashing, enkripsi Fernet |
| A-15 | Alembic Migration                    | Pengelolaan skema database                              |

### 3.3 Aset Infrastruktur

|      |                  |                               |
|------|------------------|-------------------------------|
|      |                  |                               |
| A-16 | Docker Container | Isolasi lingkungan runtime    |
| A-17 | Koneksi Database | Saluran komunikasi backend-DB |
| A-18 | Endpoint API     | Titik masuk layanan eksternal |

## 4. Threat Modeling dan Vulnerability Assessment

### 4.1 Metodologi Analisis

Tim menggunakan dua kerangka kerja utama:

1. **STRIDE** — untuk mengategorikan jenis ancaman pada setiap aliran data.
2. **DREAD** — untuk menghitung skor risiko (1-10) berdasarkan tingkat kerusakan, kemudahan eksploitasi, dan jumlah pengguna yang terdampak.

### 4.2 Titik Masuk (Entry Points)

|       |                                                                     |                        |
|-------|---------------------------------------------------------------------|------------------------|
|       |                                                                     |                        |
| EP-01 | Endpoint <code>/api/v1/auth/login</code> (Login)                    | HTTP/POST              |
| EP-02 | Endpoint <code>/api/v1/auth/users/</code> (Registrasi + Upload KTP) | HTTP/POST<br>Multipart |
| EP-03 | Endpoint <code>/api/v1/items/report-*</code> (Upload Laporan)       | HTTP/POST<br>Multipart |
| EP-04 | Endpoint <code>/api/v1/claims/</code> (Upload Bukti Klaim)          | HTTP/POST<br>Multipart |
| EP-05 | Endpoint <code>/api/v1/auth/token/refresh</code> (Refresh Token)    | HTTP/POST              |
| EP-06 | Akses Statis <code>/storage/</code>                                 | HTTP/GET               |

### 4.3 Analisis Ancaman STRIDE

|                               |                                                            |            |       |                                      |
|-------------------------------|------------------------------------------------------------|------------|-------|--------------------------------------|
|                               |                                                            |            |       |                                      |
| <b>Spoofing</b>               | Penyerang memalsukan JWT untuk bertindak sebagai user lain | A-01, A-08 | 8/10  | ✓ JWT HS256 + Argon2id               |
| <b>Tampering</b>              | Manipulasi data klaim atau status review                   | A-07       | 6/10  | ✓ Pydantic validation + ORM          |
| <b>Repudiation</b>            | User menyangkal pernah mengajukan klaim                    | A-07       | 5/10  | ✓ Audit log otomatis                 |
| <b>Information Disclosure</b> | Kebocoran data KTP atau data pribadi                       | A-03, A-04 | 9/10  | ✓ Enkripsi Fernet + RBAC             |
| <b>Denial of Service</b>      | Flood request ke endpoint login                            | A-12, A-18 | 6/10  | ✓ Rate limiting <code>slowapi</code> |
| <b>Elevation of Privilege</b> | User UMUM mengakses fungsi ADMIN                           | A-07       | 10/10 | ✓ RBAC via Role enum                 |

### 4.4 Hasil Vulnerability Assessment

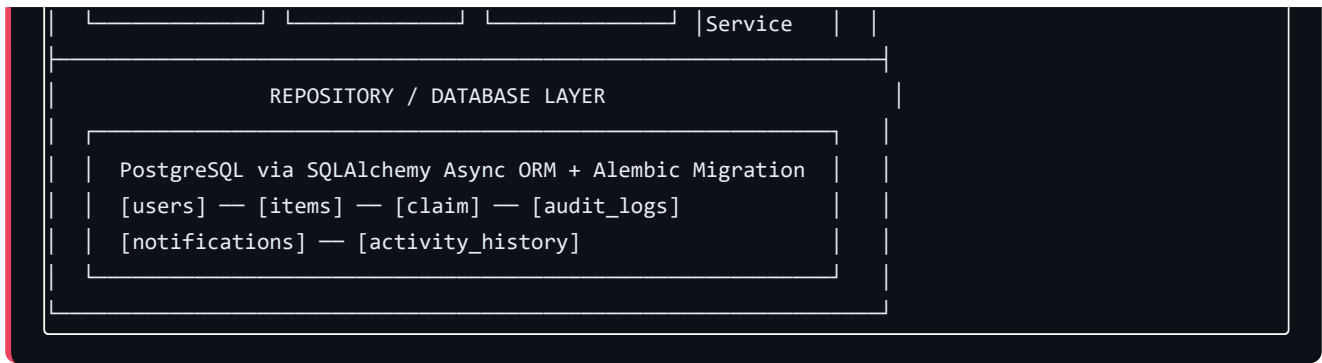
|  |  |  |  |
|--|--|--|--|
|  |  |  |  |
|--|--|--|--|

|       |                                             |        |                                               |
|-------|---------------------------------------------|--------|-----------------------------------------------|
| VA-01 | Unprotected Static Storage<br>( /storage/ ) | Tinggi | ⚠️ Planned P13                                |
| VA-02 | Lack of Rate Limiting pada login            | Sedang | ✅ Ditangani ( <code>slowapi</code> 5 req/min) |
| VA-03 | Missing Audit Trail                         | Sedang | ✅ Diimplementasikan (middleware)              |
| VA-04 | JWT Secret Key Exposure Risk                | Tinggi | ✅ <code>.env</code> + <code>.gitignore</code> |
| VA-05 | Weak File Validation (ekstensi saja)        | Sedang | ⚠️ Planned P13                                |

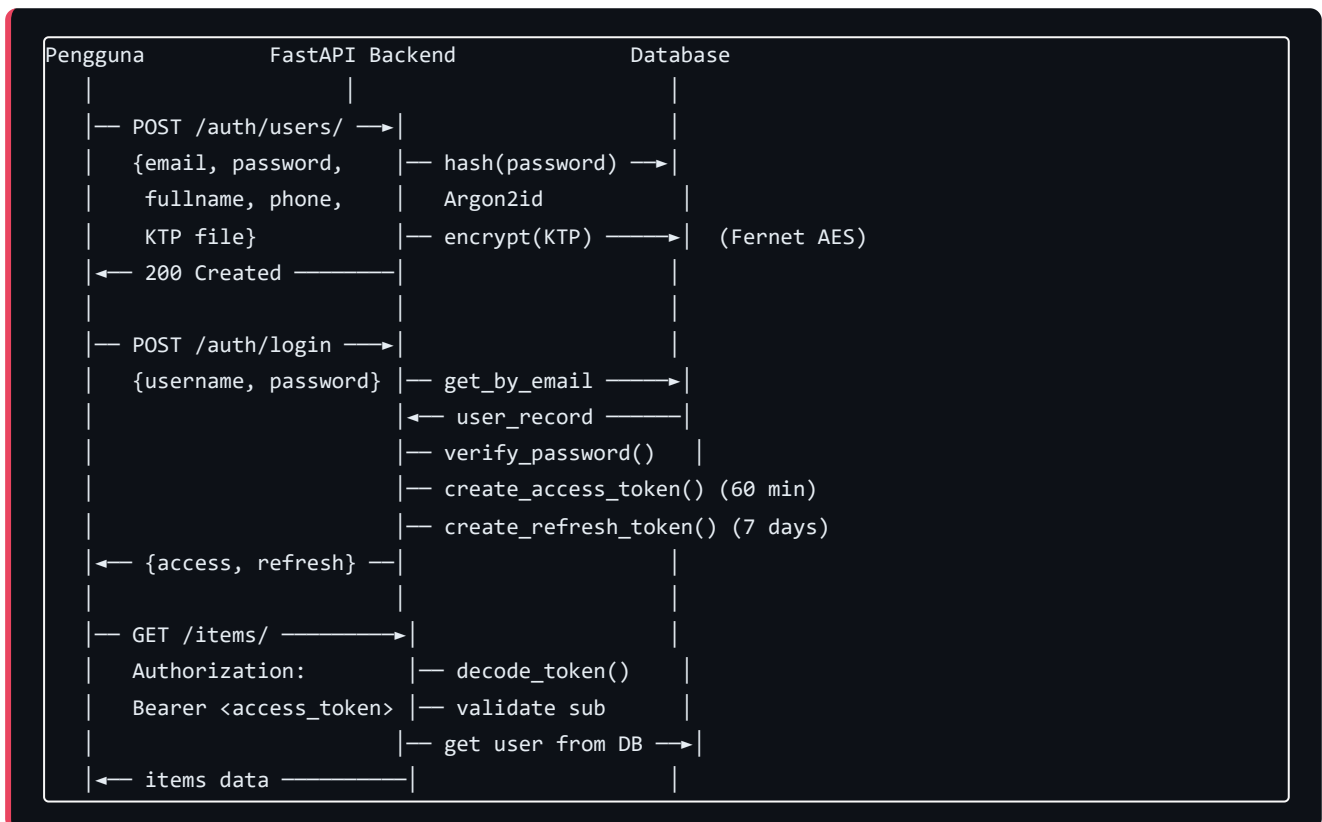
## 5. Arsitektur Keamanan

### 5.1 Arsitektur Sistem Keseluruhan

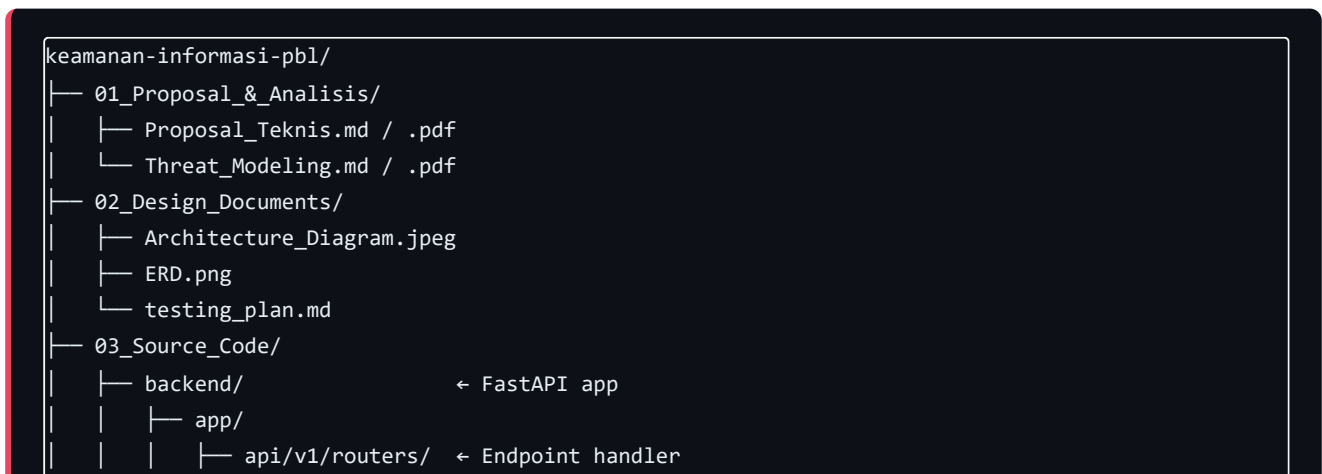




## 5.2 Alur Autentikasi



## 5.3 Struktur Repositori



```

├── domains/           ← Entitas & Service per domain
├── infrastructure/    ← Repository, Config, Storage
├── alembic/           ← Migrasi database
├── Dockerfile
├── docker-compose.yml
├── requirements.txt
├── database/
├── session.py
├── models/           ← ORM Models (6 tabel)
├── digital_signature/
├──   ├── auth_router.py ← Login, register, get_current_user
├──   ├── auth_schema.py ← Auth schemas
├──   ├── encryption.py  ← Fernet encrypt/decrypt
├──   └── utils.py        ← Hashing & JWT utilities
├── 04_Reports_& Paper/
├──   ├── Monitoring_P7/
├──   └── Final_Technical_Report/

```

## 6. Implementasi Modul Kriptografi

### 6.1 Password Hashing — Argon2id + BCrypt

Modul `digital_signature/utils.py` mengimplementasikan hashing berlapis:

```

from passlib.context import CryptContext

pwd_context = CryptContext(
    schemes=["argon2", "bcrypt_sha256", "bcrypt"],
    deprecated="auto"
)

def get_password_hash(password: str) -> str:
    return pwd_context.hash(password)

def verify_password(plain_password: str, hashed_password: str) -> bool:
    return pwd_context.verify(plain_password, hashed_password)

```

|                    |                                                         |
|--------------------|---------------------------------------------------------|
|                    |                                                         |
| Algoritma Utama    | Argon2id                                                |
| Algoritma Fallback | bcrypt_sha256, bcrypt                                   |
| Library            | <code>passlib[bcrypt]</code> , <code>argon2-cffi</code> |

Keunggulan Argon2id

Pemenang PHC 2015, resistensi GPU/ASIC, rekomendasi OWASP

## 6.2 Manajemen Token JWT

```
from jose import JWTError, jwt

def create_access_token(data, expires_delta=None) -> str:
    to_encode = data.copy()
    expire = datetime.now(timezone.utc) + (expires_delta or timedelta(minutes=60))
    to_encode.update({"exp": expire, "sub": str(data.get("sub"))})
    return jwt.encode(to_encode, settings.SECRET_KEY, algorithm=settings.ALGORITHM)

def create_refresh_token(data) -> str:
    to_encode = data.copy()
    expire = datetime.now(timezone.utc) + timedelta(days=7)
    to_encode.update({"exp": expire, "type": "refresh"})
    return jwt.encode(to_encode, settings.SECRET_KEY, algorithm=settings.ALGORITHM)
```

|                      |                                 |
|----------------------|---------------------------------|
|                      |                                 |
| Algoritma Signing    | HMAC-SHA256 (HS256)             |
| Access Token Expiry  | 60 menit                        |
| Refresh Token Expiry | 7 hari                          |
| Payload              | sub (email), exp (expiry), type |

## 6.3 Enkripsi Data Sensitif — Fernet (AES-128-CBC)

Modul `digital_signature/encryption.py` mengimplementasikan enkripsi simetris untuk data identitas pengguna:

```
from cryptography.fernet import Fernet

fernet = Fernet(settings.ENCRIPTION_KEY.encode('utf-8'))

def encrypt_string(data: str | None) -> str | None:
    """Enkripsi string (NIK) -> ciphertext base64."""
    if not data:
        return None
    return fernet.encrypt(data.encode('utf-8')).decode('utf-8')

def encrypt_bytes(data: bytes) -> bytes:
    """Enkripsi binary (foto KTP) -> encrypted bytes."""
```

```

return fernet.encrypt(data)

def decrypt_bytes(encrypted_data: bytes) -> bytes:
    """Dekripsi untuk menampilkan foto KTP ke admin."""
    return fernet.decrypt(encrypted_data)

```

|                       |                                                              |                                          |
|-----------------------|--------------------------------------------------------------|------------------------------------------|
|                       |                                                              |                                          |
| Nomor Identitas (NIK) | Fernet <code>encrypt_string()</code>                         | Kolom <code>identity_number</code> di DB |
| Foto KTP/Identitas    | Fernet <code>encrypt_bytes()</code> → <code>.enc</code> file | <code>/storage/identity/*.enc</code>     |

## 6.4 Rate Limiting — SlowAPI

Endpoint login dibatasi untuk mencegah brute-force:

```

@router.post("/login", response_model=Token)
@limiter.limit("5/minute")
async def login_for_access_token(request: Request, ...):
    ...

```

## 7. Stack Teknologi

|                  |                       |                |                               |
|------------------|-----------------------|----------------|-------------------------------|
|                  |                       |                |                               |
| API Framework    | FastAPI               | 0.115.0        | RESTful API, async support    |
| ASGI Server      | Uvicorn               | 0.30.6         | HTTP server                   |
| ORM              | SQLAlchemy            | 2.0.35         | Database abstraction (async)  |
| Database         | PostgreSQL            | 17-alpine      | Penyimpanan data relasional   |
| DB Driver        | asyncpg               | 0.31.0         | Async PostgreSQL driver       |
| Migrasi DB       | Alembic               | 1.13.2         | Schema versioning             |
| Password Hashing | passlib + argon2-cffi | 1.7.4 / 23.1.0 | Hashing & verifikasi password |
| JWT              | python-jose           | 3.5.0          | Token generation & validation |

|                  |                       |        |                            |
|------------------|-----------------------|--------|----------------------------|
| Enkripsi         | cryptography (Fernet) | 42.0.5 | Enkripsi data identitas    |
| Rate Limiting    | slowapi               | 0.1.9  | Pembatasan request         |
| Validasi Data    | Pydantic              | 2.9.2  | Schema validation          |
| Konfigurasi      | pydantic-settings     | 2.5.2  | Environment-based config   |
| Image Processing | Pillow + pillow-heif  | 11.3.0 | Penanganan upload gambar   |
| Containerization | Docker + Compose      | Latest | Deployment & isolasi       |
| Testing          | pytest + httpx        | Latest | Unit & integration testing |

## 8. Endpoint API Lengkap

### 8.1 Authentication ( /api/v1/auth )

|      |                            |          |                                                       |
|------|----------------------------|----------|-------------------------------------------------------|
|      |                            |          |                                                       |
| POST | /api/v1/auth/users/        | ✗        | Registrasi pengguna baru (dengan upload KTP opsional) |
| POST | /api/v1/auth/login         | ✗        | Login & dapatkan JWT access + refresh token           |
| POST | /api/v1/auth/token/refresh | ✗        | Refresh access token dengan refresh token             |
| GET  | /api/v1/auth/users/me      | ✓<br>JWT | Profil pengguna yang sedang login                     |

### 8.2 Users ( /api/v1/users )

|       |                  |          |       |                       |
|-------|------------------|----------|-------|-----------------------|
|       |                  |          |       |                       |
| GET   | /api/v1/users/   | ✓<br>JWT | ADMIN | Daftar semua pengguna |
| GET   | /api/v1/users/me | ✓<br>JWT | Any   | Profil diri sendiri   |
| PATCH | /api/v1/users/me | ✓<br>JWT | Any   | Update profil sendiri |

|        |                                      |          |       |                                                             |
|--------|--------------------------------------|----------|-------|-------------------------------------------------------------|
| GET    | /api/v1/users/{id}                   | ✗        | -     | Profil publik pengguna                                      |
| PATCH  | /api/v1/users/{id}                   | ✓<br>JWT | ADMIN | Update profil pengguna                                      |
| DELETE | /api/v1/users/{id}                   | ✓<br>JWT | ADMIN | Hapus pengguna                                              |
| GET    | /api/v1/users/{id}/identity-document | ✓<br>JWT | ADMIN | Lihat dokumen identitas (terenkripsi → dekripsi on-the-fly) |
| GET    | /api/v1/admin/users/{id}             | ✓<br>JWT | ADMIN | Detail lengkap pengguna (admin view)                        |
| GET    | /api/v1/admin/audit-logs             | ✓<br>JWT | ADMIN | Daftar audit log dengan paginasi                            |

### 8.3 Items ( /api/v1/items )

|      |                            |          |          |                                       |
|------|----------------------------|----------|----------|---------------------------------------|
|      |                            |          |          |                                       |
| GET  | /api/v1/items/             | ✗        | -        | Daftar semua barang                   |
| GET  | /api/v1/items/{id}         | ✗        | -        | Detail barang                         |
| GET  | /api/v1/items/search       | ✗        | -        | Filter barang (tipe, lokasi, tanggal) |
| POST | /api/v1/items/report-lost  | ✓<br>JWT | CIVITAS+ | Laporkan barang hilang                |
| POST | /api/v1/items/report-found | ✓<br>JWT | CIVITAS+ | Laporkan barang temuan                |

### 8.4 Claims ( /api/v1/claims )

|      |                     |          |                          |                          |
|------|---------------------|----------|--------------------------|--------------------------|
|      |                     |          |                          |                          |
| POST | /api/v1/claims/     | ✓<br>JWT | CIVITAS+                 | Ajukan klaim kepemilikan |
| GET  | /api/v1/claims/     | ✓<br>JWT | ADMIN (all) / User (own) | Daftar klaim             |
| GET  | /api/v1/claims/{id} | ✓<br>JWT | Any                      | Detail klaim             |

|       |                                    |          |         |                             |
|-------|------------------------------------|----------|---------|-----------------------------|
| PATCH | /api/v1/claims/{id}/review         | ✓<br>JWT | ADMIN   | Review dan putusan klaim    |
| PATCH | /api/v1/claims/{id}/mark-collected | ✓<br>JWT | Claimer | Tandai barang sudah diambil |

## 8.5 History & Notifications

|       |                                     |       |                            |
|-------|-------------------------------------|-------|----------------------------|
| GET   | /api/v1/history/me                  | ✓ JWT | Riwayat aktivitas pengguna |
| PATCH | /api/v1/history/items/{id}/returned | ✓ JWT | Tandai item dikembalikan   |
| GET   | /api/v1/notifications/              | ✓ JWT | Daftar notifikasi pengguna |

## 9. Skema Database

### Tabel `users`

| <code>id</code>                | INTEGER | PK, INDEX        | Auto-increment                  |
|--------------------------------|---------|------------------|---------------------------------|
| <code>email</code>             | VARCHAR | UNIQUE, NOT NULL | Username                        |
| <code>full_name</code>         | VARCHAR | NOT NULL         | Nama lengkap                    |
| <code>phone_number</code>      | VARCHAR | NULLABLE         | Nomor telepon                   |
| <code>identity_number</code>   | VARCHAR | NULLABLE         | NIK <b>terenkripsi</b> (Fernet) |
| <code>identity_document</code> | VARCHAR | NULLABLE         | Path file KTP <code>.enc</code> |
| <code>password_hash</code>     | VARCHAR | NOT NULL         | Hash Argon2/BCrypt              |
| <code>role</code>              | ENUM    | DEFAULT 'UMUM'   | UMUM   CIVITAS   ADMIN          |
| <code>is_active</code>         | BOOLEAN | DEFAULT TRUE     | Status akun                     |

### Tabel `items`

| id          | INTEGER      | PK           | Auto-increment          |
|-------------|--------------|--------------|-------------------------|
| title       | VARCHAR(100) | NOT NULL     | Judul barang            |
| description | TEXT         | NOT NULL     | Deskripsi detail        |
| location    | VARCHAR(255) | NOT NULL     | Lokasi kejadian         |
| image       | VARCHAR(255) | NULLABLE     | Path file foto          |
| category    | VARCHAR(64)  | NULLABLE     | Kategori barang         |
| report_type | ENUM         | NOT NULL     | LOST   FOUND            |
| status      | ENUM         | DEFAULT      | NOT_RETURNED   RETURNED |
| created_at  | DATETIME     | NOT NULL     | Timestamp pelaporan     |
| reporter_id | INTEGER      | FK(users.id) | Relasi ke pelapor       |

## Tabel **claim**

| id           | INTEGER  | PK                     | Auto-increment                |
|--------------|----------|------------------------|-------------------------------|
| request_type | ENUM     | NOT NULL               | CLAIM   FOUND_REPORT          |
| proof_text   | TEXT     | NOT NULL               | Bukti teks klaim              |
| proof_image  | VARCHAR  | NOT NULL               | Path foto bukti               |
| status       | ENUM     | DEFAULT 'PENDING'      | PENDING   APPROVED   REJECTED |
| created_at   | DATETIME | NOT NULL               | Timestamp klaim               |
| reviewed_at  | DATETIME | NULLABLE               | Timestamp review              |
| claimer_id   | INTEGER  | FK(users.id)           | Pengklaim                     |
| item_id      | INTEGER  | FK(items.id)           | Barang yang diklaim           |
| reviewer_id  | INTEGER  | FK(users.id), NULLABLE | Admin reviewer                |

## Tabel **audit\_logs**

|                          |                     |                                                            |
|--------------------------|---------------------|------------------------------------------------------------|
|                          |                     |                                                            |
| <code>id</code>          | INTEGER PK          | Auto-increment                                             |
| <code>user_id</code>     | INTEGER FK NULLABLE | User yang melakukan aksi                                   |
| <code>action</code>      | VARCHAR             | Method + path (e.g. <code>POST /api/v1/auth/login</code> ) |
| <code>endpoint</code>    | VARCHAR             | URL path                                                   |
| <code>ip_address</code>  | VARCHAR             | IP address client                                          |
| <code>user_agent</code>  | TEXT                | Browser/client info                                        |
| <code>status_code</code> | INTEGER             | HTTP response code                                         |
| <code>created_at</code>  | DATETIME            | Timestamp log                                              |

## 10. Protokol AAA

|                       |                      |                                                                                |              |
|-----------------------|----------------------|--------------------------------------------------------------------------------|--------------|
|                       |                      |                                                                                |              |
| <b>Authentication</b> | Verifikasi identitas | JWT HS256 + Argon2id, dual token (access + refresh)                            | ✓<br>Selesai |
| <b>Authorization</b>  | Menentukan hak akses | RBAC via <code>Role</code> enum, enforced di setiap endpoint                   | ✓<br>Selesai |
| <b>Accounting</b>     | Pencatatan aktivitas | Audit Log Middleware — mencatat semua request ke tabel <code>audit_logs</code> | ✓<br>Selesai |

### Implementasi Audit Log Middleware

```
@app.middleware("http")
async def audit_log_middleware(request: Request, call_next):
    # Skip static files dan dokumentasi
    if request.url.path.startswith(("/docs", "/storage", "/redoc")):
        return await call_next(request)

    response = await call_next(request)

    user_id = getattr(request.state, "user_id", None)
    action = f"{request.method} {request.url.path}"

    async with AsyncSessionLocal() as db:
```

```

log = AuditLogModel(
    user_id=user_id,
    action=action,
    endpoint=request.url.path,
    ip_address=request.client.host,
    user_agent=request.headers.get("user-agent"),
    status_code=response.status_code
)
db.add(log)
await db.commit()

return response

```

## 11. Pengujian Keamanan

### 11.1 Skenario Pengujian 3A (Authentication, Authorization, Accounting)

| AUTH-01 | Authentication  | Login dengan kredensial valid              | JWT token diterima                | ✓<br>Lulus |
|---------|-----------------|--------------------------------------------|-----------------------------------|------------|
| AUTH-02 | Authentication  | Login dengan password salah                | 401 Unauthorized                  | ✓<br>Lulus |
| AUTH-03 | Authentication  | Akses API protected tanpa token            | 401 Unauthorized                  | ✓<br>Lulus |
| AUTH-05 | Confidentiality | Enkripsi dokumen identitas saat registrasi | File tersimpan sebagai .enc       | ✓<br>Lulus |
| AUTH-07 | Confidentiality | User biasa akses KTP user lain             | 403 Forbidden                     | ✓<br>Lulus |
| AUTH-08 | Authorization   | Admin akses Audit Logs                     | Data dikembalikan                 | ✓<br>Lulus |
| AUTH-10 | Authorization   | User biasa akses endpoint admin            | 403 Forbidden                     | ✓<br>Lulus |
| AUTH-14 | Authorization   | Finder coba akses mark-collected           | 403 Forbidden                     | ✓<br>Lulus |
| ACC-01  | Accounting      | Log terekam saat login sukses              | Record di audit_logs + IP address | ✓<br>Lulus |

|        |            |                              |                                            |            |
|--------|------------|------------------------------|--------------------------------------------|------------|
| ACC-02 | Accounting | Log terekam saat login gagal | Record dengan <code>status_code=401</code> | ✓<br>Lulus |
| ACC-05 | Accounting | Paginasi Audit Logs          | Data terbatas sesuai <code>limit</code>    | ✓<br>Lulus |

## 12. Rencana Implementasi dan Kemajuan

### 12.1 Milestone Keseluruhan

|        |                                                                |           |
|--------|----------------------------------------------------------------|-----------|
|        |                                                                |           |
| P1-2   | Proposal Teknis & Analisis Kerentanan                          | ✓ Selesai |
| P3-4   | Desain Sistem (ERD, Arsitektur, Testing Plan)                  | ✓ Selesai |
| P5     | Coding Sprint I: CRUD Users, Items                             | ✓ Selesai |
| P6     | Implementasi Auth: JWT, Argon2, <code>digital_signature</code> | ✓ Selesai |
| P7     | Monitoring P7: Laporan Kemajuan Bab 1-3                        | ✓ Selesai |
| P8     | Refinement: validasi edge case, rate limiting                  | ✓ Selesai |
| P9-10  | Enkripsi Fernet untuk data identitas sensitif                  | ✓ Selesai |
| P11-12 | AAA Accounting: Audit Log Middleware                           | ✓ Selesai |
| P13    | Integration & Testing: 3A testing plan                         | ✓ Selesai |
| P14-15 | Final Release: Laporan Akhir, User Manual                      | ✓ Selesai |

### 12.2 Komponen yang Telah Diimplementasikan

|                                      |   |                                       |
|--------------------------------------|---|---------------------------------------|
|                                      |   |                                       |
| Repositori Git terstruktur           | ✓ | Struktur 4 folder sesuai ketentuan    |
| Proposal Teknis & Threat Modeling    | ✓ | Dokumen PDF tersedia                  |
| Desain Arsitektur Clean Architecture | ✓ | Domain-Driven Design                  |
| Skema Database (ERD, 6 tabel)        | ✓ | users, items, claim, audit_logs, dll. |
| Migrasi Database (Alembic)           | ✓ | Versi terkontrol                      |

|                             |   |                                         |
|-----------------------------|---|-----------------------------------------|
| CRUD Items & Claims         | ✓ | Report, list, detail, review            |
| Password Hashing (Argon2id) | ✓ | <code>digital_signature/utils.py</code> |
| JWT Authentication (HS256)  | ✓ | Access + Refresh token                  |
| RBAC 3 Peran                | ✓ | UMUM, CIVITAS, ADMIN                    |
| Enkripsi Fernet (AES)       | ✓ | NIK + dokumen KTP                       |
| Rate Limiting (slowapi)     | ✓ | 5 req/min pada login                    |
| Audit Log Middleware        | ✓ | Semua request tercatat                  |
| Docker Compose              | ✓ | Backend + PostgreSQL                    |
| Notifikasi                  | ✓ | Klaim masuk & diputuskan                |
| Pengujian 3A                | ✓ | 11 skenario lulus                       |

## 13. Referensi

1. OWASP Top 10 Web Application Security Risks (2021)
2. NIST SP 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management
3. RFC 7519: JSON Web Token (JWT)
4. Argon2 Password Hashing Competition — <https://www.password-hashing.net/>
5. FastAPI Security Documentation — <https://fastapi.tiangolo.com/tutorial/security/>
6. STRIDE Threat Modeling — Microsoft Security Development Lifecycle
7. Fernet Cryptography — <https://cryptography.io/en/latest/fernet/>
8. SlowAPI Rate Limiting — <https://slowapi.readthedocs.io/>

*Dokumen ini merupakan kompilasi seluruh luaran teknis proyek mata kuliah Keamanan Informasi (KOM1315), Program Studi Ilmu Komputer, IPB University, Semester Genap 2025/2026.*